Analyse défensive, Opération Gryphon

Nov 6, 2026 · @Marc BOHOUSSOU

Rejeu des règles Sigma hors ligne sur les journaux du contrôleur de domaine (Security et Sysmon), après l'attaque. Objectif : mesurer ce que la chaîne d'attaque laisse comme traces détectables et identifier les angles morts.

Synthèse de la couverture

Méthode : Sysmon installé sur le contrôleur de domaine (configuration SwiftOnSecurity), audit avancé activé, attaque rejouée sous journalisation, puis journaux Security et Sysmon exportés et passés dans Chainsaw avec les 3016 règles Sigma de SigmaHQ.

Résultat : la chaîne d'attaque est partiellement couverte. La domination du domaine (DCSync) et l'escalade de privilèges sont bien détectées. En revanche, le Kerberoasting, le Pass-the-Hash et l'exfiltration passent sous le radar des règles Sigma standard. Ces angles morts, détaillés plus bas, sont le cœur des recommandations.

Matrice ATT&CK annotée

Phase	Technique	Event ID	Détecté	Règle / source	Recommandation
Reconnaissance	T1087.002 Account Discovery	4661 / 4624	Non	aucune règle au seuil retenu	Baseline des requêtes SAMR, alerte sur énumération massive
Kerberoasting	T1558.003	4769	Non	règle RC4 non déclenchée (AES256)	Règle custom AES + passage en gMSA
Crackage hors ligne	T1110.002	aucun	Non détectable	hors réseau	Mots de passe longs aléatoires (gMSA)
Escalade	T1078.002 / T1098	4728 / 4732	Oui	A Member Was Added to a Security-Enabled Global Group ; User Added to Local Administrator Group	Alerte sur ajout à Domain Admins
DCSync	T1003.006	4662	Oui (48 hits)	AD Replication from Non Machine Account - DcSync Indicator	Maintenir ; restreindre les droits de réplication

Phase	Technique	Event ID	Détecté	Règle / source	Recommandation
Pass-the-Hash	T1550.002	4624 type 3 NTLM	Partiel	détecté par les règles natives Chainsaw, pas par Sigma	Alerte sur logon NTLM de compte à privilèges
Exfiltration	T1039	5145	Non	aucune règle au seuil retenu	Audit des accès aux partages sensibles

Détection connexe : 4 occurrences de Possible DC Shadow Attack, liées à l'activité de réplication du DCSync.

Constats clés

- **DCSync fortement détecté.** 48 déclenchements de la règle de réplication depuis un compte non-machine. C'est le signal le plus fiable de toute la chaîne : une réplication demandée par autre chose qu'un contrôleur de domaine est anormale par nature.
- **Le Kerberoasting a contourné la détection standard.** La règle Sigma classique cible le chiffrement RC4 (type 0x17). Or Windows Server 2025 force le Kerberos en AES256 (type 0x12) par défaut, et la demande de ticket est donc passée inaperçue. Le durcissement du chiffrement, pensé comme une protection, casse ici une détection historique. C'est le principal angle mort identifié.
- **Pass-the-Hash détecté par Chainsaw mais pas par Sigma.** Les règles natives de Chainsaw ont relevé le mouvement latéral, là où le jeu de règles Sigma au mapping utilisé est resté muet. Deux moteurs, deux couvertures : s'appuyer sur un seul laisse des trous.
- **L'escalade est visible.** L'ajout de svc_sql à un groupe à privilèges a généré les événements attendus et a été capturé.

Règle Sigma custom : Kerberoasting en AES

Pour combler l'angle mort, une règle qui détecte une demande de ticket de service (4769) chiffrée en AES vers un compte de service (compte utilisateur avec SPN, hors comptes machine et krbtgt).

```
title: Kerberoasting - demande de ticket de service en AES
id: a7f3c2d1-8b4e-4e21-9c6a-000000gryphon
status: experimental
description: Detecte une demande TGS chiffree en AES vers un compte de
service a SPN. Complete la regle RC4 classique, contournee quand le domaine
force AES (Windows Server 2025).
author: Marc Bohoussou
```

```
date: 2026/11/06
references:
  - https://attack.mitre.org/techniques/T1558/003/
logsource:
  product: windows
  service: security
detection:
  selection:
    EventID: 4769
    TicketEncryptionType:
      - '0x11'  # AES128
      - '0x12'  # AES256
  filter_machine:
    ServiceName|endswith: '$'
  filter_krbtgt:
    ServiceName: 'krbtgt'
  condition: selection and not filter_machine and not filter_krbtgt
falsepositives:
  - Demandes de tickets de service legitimes (volumineuses en production)
level: low
tags:
  - attack.credential_access
  - attack.t1558.003
```

Limite assumée : seule, cette règle est bruyante, car les tickets AES légitimes sont nombreux. Elle doit être couplée à un seuil (un même compte source demandant des tickets pour plusieurs comptes de service en peu de temps) ou à une liste blanche des comptes de service connus. La vraie parade de fond reste le passage en gMSA, dont le mot de passe aléatoire de 120 caractères rend le crackage inutile.

Recommandations

1. **Comptes de service en gMSA.** Supprime la surface de Kerberoasting à la racine : mot de passe aléatoire géré par le domaine, non crackable. Priorité haute, c'est la cause première de la compromission.
2. **Alerter sur le DCSync.** La détection existe et fonctionne : la câbler sur une alerte temps réel. Toute réplication depuis un compte non-DC doit remonter immédiatement.
3. **Restreindre les droits de réplication** (Get-Changes, Get-Changes-All) aux seuls contrôleurs de domaine, pour qu'un compte compromis ne puisse pas lancer de DCSync même admin.
4. **Déployer la règle Kerberoasting AES** ci-dessus, couplée à un seuil, pour fermer l'angle mort tant que le gMSA n'est pas généralisé.

5. **Auditer les accès aux partages sensibles** (5145) et alerter sur un accès par un compte qui n'y touche jamais, pour couvrir l'exfiltration.
6. **Croiser deux moteurs de détection** (Sigma et règles natives Chainsaw) : aucun ne couvre seul toute la chaîne.